

Clase 217 — Análisis de causa raíz

Parte: **9 — Forense digital y respuesta a incidentes** · Fuente: *NIST SP 800-61* (post-incident) y metodologías de RCA 🕒 Duración estimada: **100 min** · Nivel: **Intermedio**

🎯 Objetivo

Aprender a determinar la **causa raíz** de un incidente —no solo el síntoma— usando metodologías como los 5 Porqués, el diagrama de Ishikawa y la reconstrucción de la cadena de ataque (kill chain). Al terminar sabrás distinguir causa próxima de causa raíz y proponer acciones correctivas que eviten la recurrencia.

📖 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Distinguir** causa próxima, contribuyente y raíz.
2. **Aplicar** los 5 Porqués e Ishikawa a un incidente.
3. **Reconstruir** la cadena de ataque desde el acceso inicial.
4. **Formular** acciones correctivas verificables.
5. **Redactar** un análisis post-incidente sin culpar a personas.

📖 Temas

#	Tema	Por qué importa
1	Causa próxima vs. raíz	Arreglar el síntoma no basta
2	Los 5 Porqués	Método simple y potente
3	Diagrama de Ishikawa	Causas por categoría
4	Reconstrucción de kill chain	Ver todo el ataque
5	Cultura blameless	Aprender, no castigar
6	Acciones correctivas	Prevenir la recurrencia
7	Métricas post-incidente	MTTD, MTTR
8	Lecciones aprendidas	Cerrar el ciclo NIST

📖 Definiciones y características

- **Causa próxima:** el evento inmediato que produjo el daño (p. ej. "se ejecutó el macro"). Característica: visible pero superficial.
- **Causa raíz:** la condición de fondo que permitió todo (p. ej. "no había filtrado de adjuntos ni bloqueo de macros"). Característica: al corregirla, se previenen incidentes futuros.
- **Causa contribuyente:** factor que agravó o facilitó. Característica: no es la raíz, pero importa.

- **5 Porqués:** preguntar "¿por qué?" iterativamente hasta la raíz. Característica: simple, ideal para causas lineales.
- **Ishikawa (espina de pescado):** agrupa causas por categorías (personas, proceso, tecnología...). Característica: útil para causas múltiples.
- **Blameless post-mortem:** análisis sin culpar individuos. Característica: fomenta honestidad y aprendizaje.
- **MTTD/MTTR:** tiempo medio de detección/respuesta. Característica: métricas de mejora del programa.

Herramientas y preparación

- **Metodologías:** plantilla de 5 Porqués, diagrama de Ishikawa, plantilla de post-mortem blameless.
- **Insumos:** la timeline (clase 209), los hallazgos forenses y el mapeo ATT&CK del incidente.
- **Ejercicio aplicado:** análisis, no herramientas ofensivas.

Laboratorio guiado

Usa un incidente que ya investigaste en clases anteriores (o el caso de la clase 220).

1. Reúne los hechos: timeline, IOCs, artefactos y el mapeo ATT&CK del ataque.
2. Aplica los **5 Porqués** partiendo del impacto. Ejemplo: - ¿Por qué se cifraron los archivos? → Se ejecutó ransomware. - ¿Por qué se ejecutó? → Un usuario abrió un adjunto con macro. - ¿Por qué la macro corrió? → Las macros no estaban bloqueadas por política. - ¿Por qué llegó el correo? → El gateway no filtró el adjunto. - ¿Por qué escaló a red? → La cuenta tenía privilegios excesivos.
3. Construye el **Ishikawa** clasificando causas en: Personas, Proceso, Tecnología, Configuración.
4. Reconstruye la **kill chain** completa (acceso inicial → ejecución → persistencia → movimiento → impacto).
5. Distingue explícitamente causa próxima, contribuyentes y raíz(es).
6. Formula **acciones correctivas** verificables por cada causa raíz (bloquear macros por GPO, filtrar adjuntos, principio de mínimo privilegio) con responsable y fecha.
7. Calcula **MTTD y MTTR** del incidente a partir de la timeline.
8. Redacta el post-mortem **blameless**: qué pasó, por qué, qué mejoramos, sin señalar personas.

Ejercicios

1. Aplica los 5 Porqués a un caso de phishing.
2. Construye un Ishikawa con cuatro categorías de causa.
3. Distingue causa próxima y raíz en tres incidentes distintos.
4. Formula tres acciones correctivas verificables.
5. Calcula MTTD y MTTR de una timeline dada.
6. Reescribe un post-mortem con culpas en versión blameless.

Reto verificable

Realiza el análisis de causa raíz completo de un incidente que investigaste, entregando el árbol de 5 Porqués, el Ishikawa, la kill chain, y al menos tres acciones correctivas que ataquen causas raíz (no

síntomas), cada una con criterio de verificación.

Criterio de aceptación: cada acción correctiva ataca una causa raíz identificada (no un síntoma), tiene responsable, fecha y una forma objetiva de verificar que se implementó. El post-mortem no señala a ningún individuo.

⚠ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Arreglas el síntoma y recurre	Te quedaste en la causa próxima. Sigue preguntando "por qué".
El análisis busca culpables	Cultura de culpa. Adopta el enfoque blameless.
Acciones vagas ("mejorar seguridad")	No verificables. Hazlas concretas y medibles.
Una sola causa asumida	Muchos incidentes tienen varias. Usa Ishikawa.
No se implementan las acciones	Sin responsable/fecha. Asígnalos y da seguimiento.

? Preguntas frecuentes

? **¿Causa próxima o raíz?** La próxima es el disparo inmediato; la raíz es la condición de fondo. Corrige la raíz para prevenir recurrencia.

? **¿Por qué blameless?** Porque culpar oculta la verdad. Un análisis sin culpa obtiene información honesta y mejora el sistema, no castiga a la persona.

? **¿5 Porqués o Ishikawa?** 5 Porqués para causas lineales; Ishikawa cuando hay múltiples factores por categoría. A menudo se combinan.

? **¿Para qué sirven MTTD/MTTR?** Miden la eficacia del programa de respuesta y permiten fijar objetivos de mejora incidente a incidente.

🔗 Referencias

- NIST SP 800-61 Rev. 2 (Lessons Learned): <https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final>
- Lockheed Martin — Cyber Kill Chain: <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>
- Google SRE — Postmortem Culture: <https://sre.google/sre-book/postmortem-culture/>
- MITRE ATT&CK: <https://attack.mitre.org/>

➡ Siguiente clase

Clase 218 - Reporte forense y aspectos legales